

Note de cadrage Santé OS

Intégration ESP32 et sécurisation de la plateforme

Projet Santé IA et IoT • Équipe Lyon • Version révisée du 2 octobre 2026

Lien du repository de l'ancien projet : https://github.com/Mathilde01m/Detection_malaise_EHPAD

Objet et résultat attendu

Nous souhaitons faire évoluer le projet de surveillance en EHPAD réalisé l'an dernier en remplaçant les deux simulateurs Python d'acquisition par un ESP32 simulé. Nous conservons le backend Python et les services existants, puis nous corrigeons les points qui empêchent une démonstration cohérente et sécurisée.

Cette note reprend les consignes et les deux grilles d'aide fournies : dimensions techniques, produit et réglementaires. Elle présente l'architecture de départ, les écarts cotés en criticité et effort, l'intégration ESP32 envisagée et les protections à développer. Les propositions restent à vérifier par un premier essai de connexion et des tests de bout en bout.

Périmètre de cette évolution

La cible immédiate est un prototype pédagogique avec des données fictives, des scénarios reproductibles, des accès contrôlés et des événements enregistrés. Le passage à un ESP32 simulé permet de travailler le firmware et les échanges IoT. Il reste une simulation et ne démontre pas la fiabilité de capteurs physiques ou la performance clinique du système.

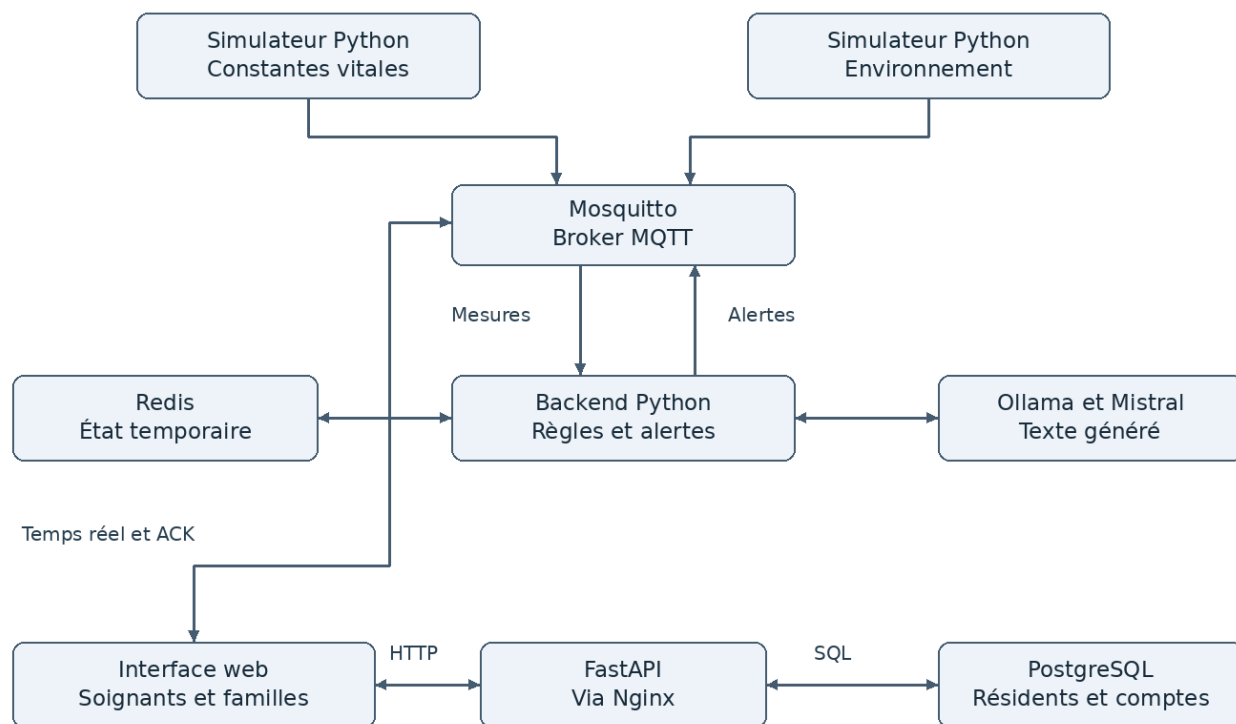
Le matériel réel, l'évaluation clinique, un modèle prédictif validé et l'exploitation continue en établissement sont recensés comme des écarts à long terme. Ils ne sont pas des prérequis à la démonstration ESP32 définie ici. Aucun calendrier ou Gantt n'est établi ; l'effort est coté par complexité relative.

Ce que le projet comporte déjà

- Deux générateurs Python publient des constantes vitales et des événements environnementaux sur MQTT à partir de données CSV et de scénarios programmés.
- Mosquitto distribue les messages ; le backend applique des seuils et une graduation temporelle des alertes. Redis conserve l'état courant et un historique court.
- Mistral via Ollama génère un texte pour les niveaux d'alerte élevés. Une interface web présente les résidents, les constantes, les alertes et une carte des chambres.
- FastAPI propose une connexion JWT et des lectures de résidents. PostgreSQL contient un schéma de données, des comptes et les associations famille résident. Docker Compose assemble les services.

Sources : archive Projet final 2.zip et deux grilles des écarts Digi4 fournies par l'équipe.

I] Architecture du projet existant



Aucun flux de mesures MQTT vers PostgreSQL dans le code fourni.

Figure 1 Architecture reconstituée à partir du code et de Docker Compose. Les flèches représentent les échanges implémentés. ACK désigne l'acquittement envoyé par le navigateur.

Deux circuits à raccorder

Le circuit MQTT alimente le backend et le navigateur en temps réel. Le circuit HTTP relie le navigateur à FastAPI, puis à PostgreSQL pour l'authentification et la consultation. Aucun consommateur fourni n'enregistre les mesures MQTT et les alertes dans les tables PostgreSQL : l'existence du schéma SQL ne suffit donc pas à garantir un historique durable.

Limites observées dans les fichiers

- backend_IA/processor.py n'appelle aucune prédiction du moteur IA. train_all_models.py utilise des étiquettes aléatoires pour le LSTM ; aucun modèle entraîné n'est fourni dans backend_IA/models.
- config/mosquitto.conf autorise les connexions anonymes. frontend/script.js utilise MQTT sans TLS ni JWT. Le filtrage de la vue famille ne protège pas les topics.
- L'alerte importante attend Mistral. Une intervention force le statut local à stable et conserve la note seulement dans le navigateur ; le backend prévoit une suppression temporaire des alertes.
- La vue famille attend risk_score, alors que le simulateur expose ai_risk_score. Un état commun reste à définir pour toutes les vues.

Les quatre couches sont l'acquisition simulée, le transport MQTT, le traitement serveur et l'application avec stockage. Une passerelle réseau et des contrôles d'accès seront ajoutés pour l'ESP32.

II.1] Écarts et cotation du travail

Criticité C : 1 mineure, 2 faible, 3 importante, 4 majeure, 5 critique pour la confidentialité, la fiabilité ou l'objectif du projet.

Effort E : 1 très faible, 2 faible, 3 moyen, 4 élevé, 5 très élevé ou nécessitant une validation terrain. Les notes portent sur la correction de l'écart décrit, sans estimation en jours.

Le périmètre indique Démo pour l'évolution ESP32 et Produit pour les travaux nécessaires à une utilisation réelle en EHPAD. Un écart Produit reste visible dans l'évaluation même s'il ne sera pas résolu dans le prototype.

N°	Écart constaté	Développement attendu	C	E	Périmètre
01	Acquisition Python à remplacer	Créer un firmware ESP32 simulé, les scénarios et la connexion MQTT sécurisée.	4	3	Démo
02	Aucun capteur réel raccordé	Choisir, calibrer et intégrer le matériel, puis vérifier les mesures sur site.	5	5	Produit
03	Événements déjà qualifiés dans les scénarios	Séparer les données observées et la vérité du scénario ; détecter les événements à partir de signaux mesurés.	5	5	Produit
04	Modèles prédictifs non utilisés	Constituer un jeu de données pertinent, évaluer les modèles et intégrer les prédictions.	5	5	Produit
05	Absence de validation clinique	Mesurer les faux positifs, événements manqués et délais avec des professionnels.	5	5	Produit
06	Publication bloquée par Mistral	Publier l'alerte immédiatement ; générer le texte dans une tâche séparée.	5	2	Démo
07	Gravité initiale et priorités incomplètes	Traiter immédiatement les scénarios critiques prévus et vérifier les conflits entre événements.	5	3	Démo
08	Acquittement assimilé à un retour stable	Distinguer prise en charge et résolution ; autoriser une nouvelle alerte en cas d'aggravation.	5	3	Démo
09	MQTT anonyme et non chiffré	Activer TLS, identifier les clients et limiter les topics par droits.	5	4	Démo
10	Comptes et secrets de démonstration	Remplacer les secrets codés, les mots de passe communs et gérer les sessions.	5	3	Démo

L'intégration ESP32 est un nouvel objectif. Les cotations des autres écarts prolongent l'analyse de l'existant. Un score de criticité élevé n'implique pas automatiquement un effort élevé : supprimer l'attente du LLM est une correction ciblée à fort impact.

II.2]Écarts et cotation du travail suite

N°	Écart constaté	Développement attendu	C	E	Périmètre
11	Absence d'ingestion PostgreSQL	Enregistrer les mesures et alertes, actualiser l'état courant et relire l'historique.	4	4	Démo
12	Notes uniquement dans le navigateur	Créer une API d'intervention et enregistrer note, auteur, date et alerte associée.	4	3	Démo
13	Livraison et reprise incomplètes	Utiliser QoS 1 pour les événements retenus, gérer doublons, reconnections et abonnements.	5	4	Démo
14	Données absentes ou anciennes mal gérées	Valider les messages et horodatages ; afficher indisponible plutôt qu'une valeur normale par défaut.	5	3	Démo
15	État Redis insuffisamment contrôlé	Normaliser les booléens, vérifier les écritures et définir les règles de récupération.	4	2	Démo
16	Statut famille incohérent	Diffuser un état calculé commun via le serveur, limité au résident autorisé.	4	2	Démo
17	Notification limitée au navigateur	Ajouter un canal adapté et une escalade vers un autre soignant si nécessaire.	5	4	Produit
18	Gestion des résidents et capteurs incomplète	Ajouter la création, modification et affectation, avec des droits administrateur.	3	3	Produit
19	Tests et exploitation incomplets	Tester les scénarios et pannes ; prévoir supervision et restauration. La démo couvre les tests essentiels.	4	4	Démo puis Produit
20	Texte Mistral sans validation documentée	Afficher son origine, prévoir un secours et contrôler son usage. Valider la qualité avant tout usage réel.	5	4	Démo puis Produit
21	Cadre de mise en service non documenté	Définir les conditions de traitement et conservation des données réelles et l'évaluation applicable à l'usage visé.	5	5	Produit

Ordre de décision sans planning

La première décision est de confirmer l'accès réseau entre le simulateur et notre broker. Nous fixons ensuite le format des messages et les droits de chaque client. L'interface, la persistance et les scénarios seront vérifiés ensemble sur la chaîne complète. Ces dépendances guident les choix techniques sans imposer de calendrier.

III] Compléments issus des deux grilles Digi4

Les grilles complètent les écarts logiciels par la précision du matériel, son maintien en condition de sécurité et la préparation du produit. Les notes ci-dessous sont provisoires. Elles concernent l'écart vers un usage réel ; les aspects documentaires peuvent être étudiés dans le projet pédagogique.

N°	Écart constaté	Travail attendu	C	E	Périmètre
22	Capteur et artefacts non évalués	Définir précision attendue, calibration et essais avec bruit, mouvement, mauvais contact ou données manquantes.	5	4	Produit
23	Autonomie radio et robustesse non mesurées	Choisir le device réel ; mesurer consommation, portée, pertes réseau et résistance aux conditions d'usage.	4	4	Produit
24	Mises à jour du device non prévues	Prévoir version du firmware, mises à jour authentifiées, retour arrière sûr et rotation des secrets.	5	4	Produit
25	Aucun lien avec le SI hospitalier	Définir le besoin d'échange, les identifiants, unités et un adaptateur FHIR compatible avec le SI cible [5].	3	4	Produit
26	Statut du futur produit non qualifié	Formaliser la finalité revendiquée et analyser la qualification médicale selon le guide MDCG [6].	5	4	Produit
27	Hébergement AIPD et consentement non documentés	Définir les acteurs, bases légales, information, accès famille, conservation, AIPD et cadre HDS [7 à 9].	5	4	Produit
28	Tests avec les usagers non documentés	Évaluer avec soignants, aidants et résidents la compréhension des alertes et l'intégration au travail quotidien.	4	4	Produit
29	Performance non comparée à une référence	Fixer un protocole, une référence indépendante et des indicateurs de sensibilité, précision et délais.	5	5	Produit
30	Modèle économique non documenté	Identifier le payeur, la valeur attendue et les coûts de matériel, installation, hébergement et maintenance.	3	3	Produit
31	Analyse de risques non formalisée	Relier panne et erreur à leurs conséquences, protections, preuves de test et risque résiduel.	5	3	Démo puis Produit

Couverture des grilles : données, capteur, device, sécurité device, IA et interopérabilité pour la technique ; statut, risques, données personnelles, usage, validation et modèle économique pour le produit. Les 31 écarts détaillent ces 12 dimensions ; leurs scores ne constituent pas une mesure de conformité.

IV] Préparation du produit et maîtrise des risques

Finalité et statut à clarifier

Notre démonstration utilise des situations fictives. Pour un futur produit, la détection de malaises et la surveillance de constantes doivent être décrites dans une finalité précise : utilisateurs, population, situations couvertes et décisions attendues. La qualification dépend de cette finalité ; nous ne pouvons pas conclure à un simple produit de bien-être à partir du prototype. L'analyse s'appuiera sur le guide MDCG et précédera tout usage clinique [6].

Données personnelles et hébergement

Avant des données réelles, nous devons désigner le responsable du traitement et ses prestataires, documenter les finalités, la base légale et les conditions de traitement des données de santé. Le consentement est une possibilité à examiner selon le contexte, sans le supposer systématiquement obligatoire [8]. L'information des personnes et les autorisations de la vue famille devront être formalisées.

L'AIPD, analyse d'impact relative à la protection des données, sera examinée au regard du suivi de personnes vulnérables et des critères CNIL [7]. Nous préciserons durées de conservation, droits, sauvegardes et localisation des données. Si l'hébergement réel est externalisé, le champ des exigences HDS sera vérifié selon le cadre de l'ANS [9]. Ces travaux sont distincts du chiffrement technique.

Première analyse des défaillances

Défaillance	Conséquence possible	Protection et preuve attendues
Capteur ou réseau arrêté	Une situation anormale peut passer inaperçue.	Heartbeat, état indisponible et signalement de panne ; tester une interruption.
Alerte retardée ou acquittée à tort	La prise en charge peut être retardée.	Émission indépendante du LLM, suivi de réception et nouvelle alerte si aggravation ; tester le parcours.
Faux positif ou mauvais résident	Surcharge des soignants ou intervention mal orientée.	Contrôle identité et qualité des mesures ; tester une erreur d'affectation et mesurer les fausses alertes.

Ce tableau amorce l'analyse ; il ne démontre pas un risque maîtrisé. Pour chaque défaillance, il faudra documenter gravité, fréquence estimée, protection, test et risque résiduel. Aucun bénéfice clinique ou réduction de risque n'est établi par la seule simulation.

Usage et validation contre une référence

Les tests d'usage porteront sur la lecture des alertes, l'acquiescement, la fatigue liée aux notifications et la compréhension de la vue famille. La recette ESP32 vérifie le logiciel. La performance d'un produit exigera une référence indépendante, par exemple une mesure de référence et des événements annotés, avec données d'essai séparées de l'apprentissage. Nous mesurerons sensibilité, précision des alertes, faux positifs par résident et par jour, et délai de bout en bout.

Hypothèse économique à vérifier

Nous proposons d'étudier un financement par l'EHPAD ou son groupe gestionnaire, avec équipement initial et service de maintenance. Cette hypothèse reste à confronter aux besoins et au budget des établissements. Le coût total devra intégrer matériel, installation, remplacement, réseau, hébergement, support et formation ; aucune rentabilité ni prise en charge financière n'est démontrée.

V] Intégration envisagée du simulateur ESP32

Choix proposé et rôle du firmware

Nous proposons Wokwi pour simuler un ESP32 et son réseau WiFi [1]. Le firmware sera développé en C ou C++ pour porter les scénarios d'acquisition hors des scripts Python. Le client ESP-MQTT d'Espressif est une option adaptée à étudier car il prend en charge TLS, l'authentification et QoS 1 [2]. La version du SDK et la chaîne de compilation devront être figées après un premier essai sous Wokwi.

Le firmware publiera les constantes et les états de capteurs. La décision d'alerte, la gestion des utilisateurs, PostgreSQL et Mistral resteront sur le serveur. Un premier ESP32 simulé sera associé à un résident fictif ; le fonctionnement avec plusieurs appareils sera ensuite vérifié. Les deux générateurs Python seront désactivés dans le mode ESP32 pour éviter deux sources concurrentes.

Scénarios démontrables

Les entrées pourront combiner des valeurs programmées et des commandes virtuelles : variation de fréquence cardiaque et de SpO2, bouton de scénario de chute, ouverture de porte ou présence simulée. Ces commandes représentent des cas de test. Elles ne remplacent pas un oxymètre ou une mesure clinique. Un scénario normal, une dégradation progressive, une chute et une coupure réseau serviront à vérifier le comportement de la plateforme.

Contrat de messages et compatibilité

Flux	Topic et contenu attendu
Constantes	ehpad/residents/{id}/vitals : conserver heart_rate, spo2, temperature, systolic_bp et diastolic_bp lorsqu'ils sont disponibles.
Environnement	ehpad/residents/{id}/environment : conserver les champs observés de présence, porte et mouvement. Les indicateurs de scénario seront explicitement fictifs.
Disponibilité	ehpad/devices/{device_id}/status : état de connexion, heartbeat et message de dernière volonté MQTT.
Métadonnées	resident_id, device_id, schema_version, timestamp UTC, boot_id, sequence et simulated=true ; ne pas envoyer nom ou pathologie.

Le backend vérifiera que le résident du topic correspond au message et à l'affectation du client authentifié. Les champs ajoutés doivent être acceptés sans casser la compatibilité. Les métadonnées préviennent les mélanges de résidents et permettent de dédupliquer les retransmissions avec le couple boot_id et sequence.

Les événements seront transportés en QoS 1 avec une file bornée et une durée de validité. QoS 1 autorise des doublons et ne prouve pas l'enregistrement en base : un accusé applicatif est nécessaire si le firmware doit confirmer la persistance. Une donnée trop ancienne ne doit pas redevenir une mesure courante.

8 Architecture cible et accès réseau

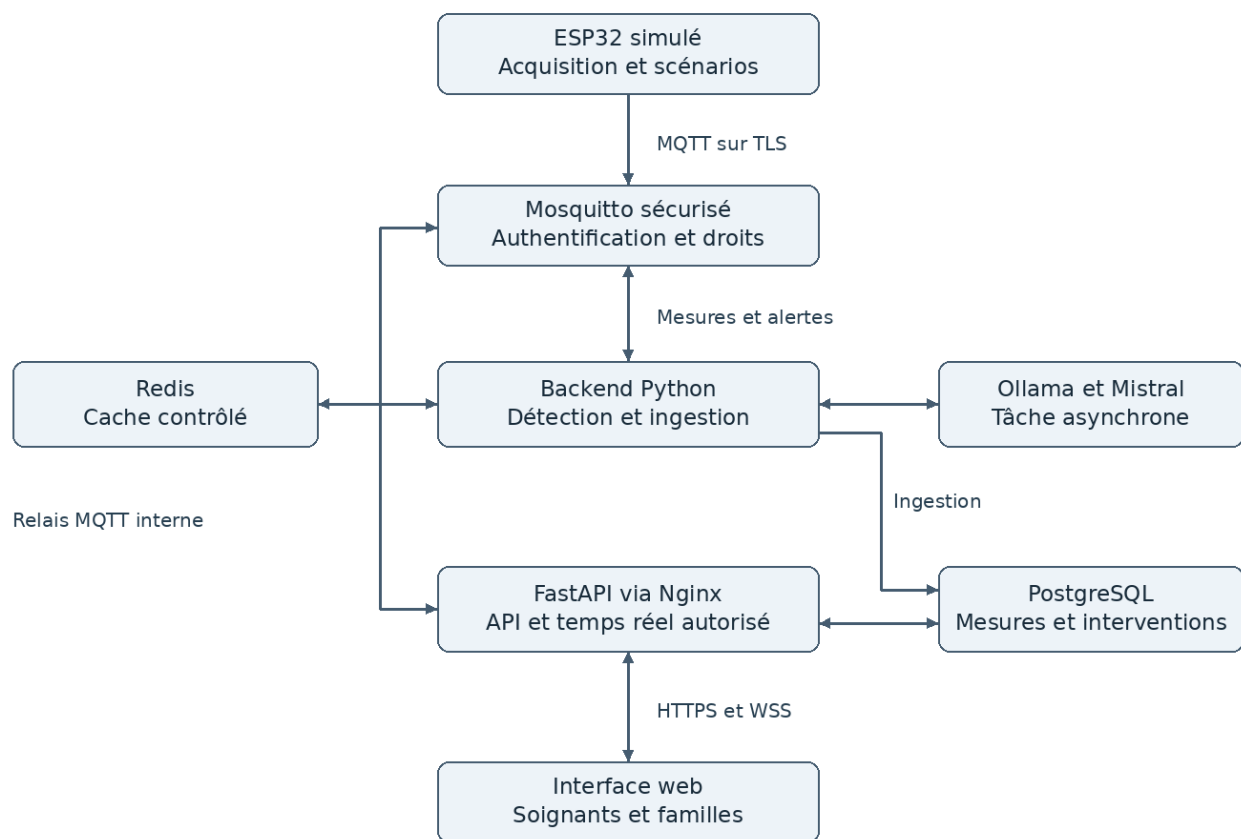


Figure 2 Architecture proposée à développer. Le navigateur reçoit les données autorisées via FastAPI en WSS, WebSocket chiffré. Il n'accède plus directement au broker. L'acquittement passe par l'API, qui vérifie l'utilisateur puis publie l'événement interne.

Connexion à notre environnement Docker

Le simulateur ne peut pas utiliser directement le nom Docker `mqtt-broker`. La passerelle privée Wokwi permet d'atteindre la machine hôte via `host.wokwi.internal` [1]. Nous proposons un listener MQTT TLS dédié, par exemple sur le port 8883, et un premier essai de publication avant le portage des scénarios.

La passerelle privée nécessite une offre Wokwi compatible et un navigateur autre que Safari [1]. L'équipe devra vérifier ces conditions. Le certificat du broker devra couvrir le nom de connexion ; sa validation restera active.

Une alternative est un broker de test administré par l'équipe et joignable en TLS. La passerelle publique Wokwi n'accède pas au réseau local et exclut les données sensibles [1]. Les essais utiliseront des données fictives et des identifiants de test révocables.

Développements côté serveur

Le backend validera les messages, actualisera Redis et enregistrera les mesures et alertes dans PostgreSQL. FastAPI relaiera les événements autorisés. La reprise MQTT sera testée et Mistral fonctionnera séparément de l'émission des alertes.

VI] Cybersécurité de la chaîne complète

La protection doit couvrir les appareils, MQTT, l'API et les vues web. Dans l'existant, une connexion JWT à l'API peut être contournée pour les données temps réel par un accès direct au broker anonyme. L'architecture cible place le contrôle des utilisateurs sur le serveur.

Risque identifié	Protection à développer
Lecture ou publication MQTT non autorisée	Désactiver les accès anonymes, créer une identité par appareil et service, limiter les topics par ACL et vérifier le certificat TLS [3].
Acquittement falsifié ou accès à un autre résident	Passer par une API authentifiée ; vérifier rôle et affectation du résident pour chaque action et chaque abonnement temps réel [4].
Vol de session ou accès après déconnexion	Utiliser HTTPS et WSS ; gérer expiration et révocation. Si un cookie de session est retenu, prévoir HttpOnly, Secure, SameSite et la protection CSRF adaptée.
Messages malformés, anciens ou trop nombreux	Valider JSON, types, taille et identité ; limiter le débit ; contrôler horodatage et séquence. Les limites seront adaptées aux tests attendus.
Injection de contenu dans le navigateur	Afficher les notes et textes Mistral comme du texte ; remplacer les insertions innerHTML de données non fiables et ajouter une politique de contenu.
Exposition de secrets et services internes	Retirer les secrets du code et des projets partagés, les renouveler et fournir seulement des exemples de configuration. Garder Redis, PostgreSQL et Ollama sur le réseau interne.
Perte de données ou interruption silencieuse	Journaliser les erreurs et actions, surveiller heartbeat et dernière mesure ; sauvegarder PostgreSQL et vérifier une restauration.

Droits prévus

L'ESP32 peut publier uniquement les données du résident qui lui est affecté et son état de connexion. Il ne peut ni lire les données des autres résidents ni acquitter une alerte. Le backend peut consommer les mesures et publier les alertes. La famille consulte uniquement son proche ; le personnel accède aux résidents autorisés et les actions administratives restent réservées aux administrateurs.

Sessions et informations sensibles

Le filtrage des vues sera imposé par le serveur, y compris lors des connexions WebSocket. Nous contrôlerons l'origine, l'expiration de session et les droits des actions [4]. Aucun secret, jeton ou contenu médical complet ne sera écrit dans les journaux. Le texte Mistral sera présenté comme généré et ne déclenchera aucune action automatique sur un résident.

VII] Vérification et livrables attendus

Les critères suivants constituent une recette technique proposée. Ils décrivent des résultats à obtenir et ne sont pas des tests déjà réussis. Les délais chiffrés sont des objectifs de démonstration à mesurer.

Vérification	Résultat attendu
Chaîne ESP32	Une mesure fictive publiée par l'ESP32 apparaît dans la bonne fiche et est enregistrée en base ; aucune source Python concurrente n'est active.
Alerte et Mistral	Après réception serveur d'un événement critique du scénario, l'alerte est visible en moins de 5 secondes, même si Mistral est lent ou arrêté.
Intervention	L'utilisateur autorisé acquitte l'alerte ; note, auteur et date sont conservés après rechargement. Une aggravation peut déclencher une nouvelle alerte.
Panne et données anciennes	Avec un heartbeat de 10 secondes, une absence de plus de 30 secondes est signalée. La reconnexion ne réinjecte pas une ancienne mesure comme actuelle.
Droits et refus	Un client MQTT anonyme est refusé ; un ESP32 ne publie pas pour un autre résident ; une famille ne consulte ni n'acquitte un résident non associé.
TLS et contenu	Un certificat serveur non approuvé provoque un refus. Une note contenant du HTML est affichée comme texte, sans exécution dans le navigateur.
Reprise et cohérence	Après redémarrage du backend ou du navigateur, les alertes actives sont retrouvées et les doublons ne créent pas plusieurs interventions.

Éléments à remettre

Cette note et les deux schémas répondent au cadrage et à la cotation. L'implémentation devra être accompagnée du projet de simulation ESP32, du firmware, d'un contrat de messages versionné, d'une configuration sans secrets, d'un guide de lancement et de preuves de recette. Les points non résolus seront conservés dans le tableau des écarts avec leur périmètre.

Pour préparer le futur produit, nous remettrons également une description de la finalité, une analyse des risques, un protocole de validation et de tests d'usage, une proposition d'échange avec le SI, ainsi qu'une première étude des conditions de traitement des données et du modèle économique. Ces documents constituent des travaux proposés, sans prétendre à une qualification ou certification obtenue.

Ce que le passage à ESP32 permettra de démontrer

La simulation vérifiera l'exécution d'un firmware, le format des messages et le comportement du système lors des scénarios et interruptions. Les mesures de consommation réelle, l'autonomie, la précision clinique, la robustesse physique et l'acceptation par les usagers resteront à évaluer sur un dispositif et un terrain adaptés.

Annexes :

Sources et limites de cette note

Les constats sur l'existant proviennent du code de l'archive Projet final 2.zip. Les deux images intitulées Grille des écarts technique et Grille des écarts produit et réglementaire définissent les dimensions attendues. Leurs exemples d'écarts typiques ne sont pas considérés comme des preuves sur notre projet.

Les architectures cibles, cotations et modalités de test sont des propositions de cadrage. Les choix de simulateur, bibliothèques et accès réseau devront être confirmés par un premier essai. L'absence de document ou de résultat dans l'archive est distinguée d'une preuve de non-conformité. Les références ci-dessous ont été consultées le 2 octobre 2026.

Documentation de la simulation et de la sécurité

[1] Wokwi — ESP32 WiFi Networking
<https://docs.wokwi.com/guides/esp32-wifi>

[2] Espressif — ESP-MQTT
<https://github.com/espressif/esp-mqtt>

[3] Eclipse Mosquitto — Configuration et contrôle des accès
<https://mosquitto.org/man/mosquitto-conf-5.html>

[4] OWASP — WebSocket Security Cheat Sheet
https://cheatsheetseries.owasp.org/cheatsheets/WebSocket_Security_Cheat_Sheet.html

Interopérabilité et préparation réglementaire

[5] HL7 — FHIR R4 Observation
<https://hl7.org/fhir/R4/observation.html>

[6] Commission européenne — MDCG 2019 11 révision 1 de juin 2025
https://health.ec.europa.eu/document/download/b45335c5-1679-4c71-a91c-fc7a4d37f12b_en?filename=mdcg_2019_11_en.pdf

[7] CNIL — Analyse d'impact relative à la protection des données
<https://www.cnil.fr/fr/RGPD-analyse-impact-protection-des-donnees-aipd>

[8] CNIL — Consentement et bases légales
<https://www.cnil.fr/fr/les-bases-legales/consentement>

[9] Agence du Numérique en Santé — Certification HDS
<https://esante.gouv.fr/produits-services/hds>